Sistemi elektronskog plaćanja

Projektni zadatak

MAS - Softversko inženjerstvo i informacione tehnologije - 2026/2027

Parking sistem

Online parking sistem predstavlja veb aplikaciju koja omogućava korisnicima da pronađu, aktiviraju i elektronski plate parking na odabranoj parking zoni ili lokaciji. Korisnik bira parking zonu ili parking lokaciju, unosi registarsku oznaku vozila i bira željeno trajanje parkiranja. Na osnovu odabranih parametara sistem izračunava cenu parkiranja i omogućava elektronsko plaćanje.

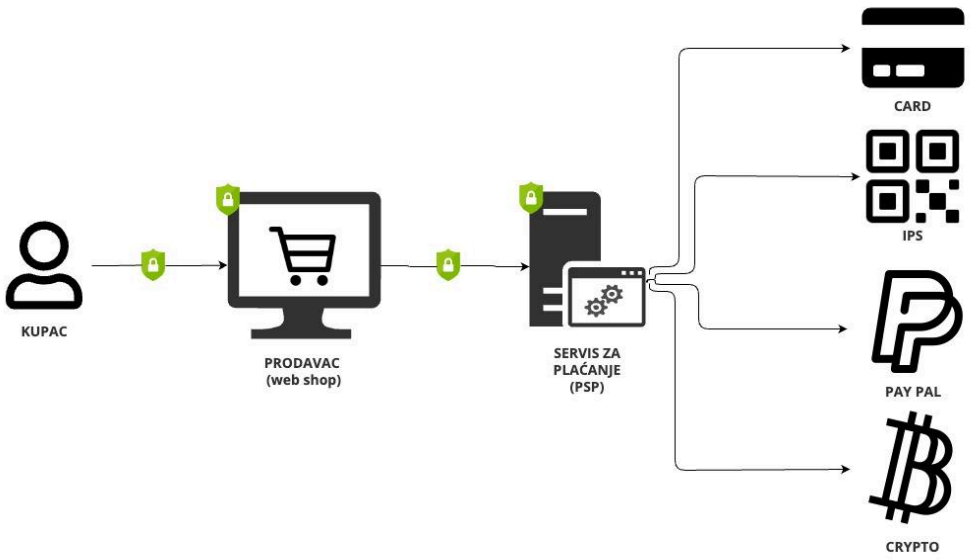
Aplikacija omogućava korisnicima:

- registraciju i prijavu u aplikaciji kako bi mogli koristiti usluge sistema;
- pregled dostupnih parking zona i parking lokacija sa informacijama o ceni, dozvoljenom trajanju i pravilima parkiranja;
- unos i čuvanje jednog ili više vozila, odnosno registarskih oznaka;
- pokretanje parking sesije izborom zone/lokacije, vozila i trajanja parkiranja;
- automatski obračun cene parkiranja pre pokretanja plaćanja;
- elektronsko plaćanje parkinga;
- pregled trenutno aktivnih parking sesija i vremena preostalog do isteka;
- produžavanje aktivne parking sesije dodatnim plaćanjem, ukoliko pravila odabrane zone to dozvoljavaju;
- dobijanje obaveštenja određeno vreme pre isteka parkinga (podrazumevano vreme je 5 min);
- pregled istorije parkiranja i izvršenih plaćanja.

Svaka parking zona/lokacija poseduje cenovnik, maksimalno dozvoljeno trajanje parkiranja i pravila produženja. Pravila mogu obuhvatati minimalno i maksimalno trajanje parkiranja, dozvoljene vremenske intervale, radno vreme naplate, maksimalan broj produženja, zabranu produženja u određenim zonama i različite cene u zavisnosti od zone ili vremena parkiranja. Sistem mora sprečiti pokretanje ili produženje parking sesije suprotno pravilima odabrane zone. Cena koja se prikazuje korisniku mora odgovarati iznosu koji se prosleđuje na plaćanje.

Nakon uspešnog plaćanja sistem aktivira parking sesiju i čuva podatke o vozilu, zoni/lokaciji, početku i kraju parkiranja, iznosu, valuti i identifikatoru transakcije. Neuspešno ili nedovršeno plaćanje ne sme aktivirati parking sesiju.

Sva plaćanja se izvršavaju pomoću *Payment Service Provider*-a (u daljem tekstu PSP), koji predstavlja odvojeni sistem. Nakon što korisnik odabere parking zonu/lokaciju, vozilo i trajanje parkiranja, Online parking sistem kreira nalog za parking i zahtev za inicijalizaciju transakcije. Korisnik se zatim preusmerava na PSP, gde bira jedan od načina plaćanja na koje je parking sistem prethodno pretplaćen (Slika 1).



SLIKA 1. TOK KOMUNIKACIJE PRILIKOM PLAĆANJA KOJI PRIKAZUJE PSP KAO POSREDNIKA U KOMUNIKACIJI

Produženje parking sesije

Aktivna parking sesija može se produžiti ukoliko pravila odabrane zone/lokacije to dozvoljavaju. Produženje parkinga predstavlja novu kupovinu i novu platnu transakciju, ali mora biti povezano sa postojećom parking sesijom.

Pre inicijalizacije produženja parking sistem proverava da li je sesija aktivna, da li je produženje dozvoljeno i koliko maksimalno dodatnog vremena korisnik može kupiti. Na osnovu izabranog trajanja sistem računa dodatni iznos i inicijalizuje novu transakciju prema PSP-u.

Ako dodatno plaćanje uspe, vreme isteka postojeće parking sesije se produžava. Ako plaćanje ne uspe, bude otkazano, prethodno plaćeno vreme parkiranja mora ostati nepromenjeno.

Posebno je potrebno obraditi situaciju u kojoj korisnik započne produženje neposredno pre isteka parkinga, a konačan status transakcije stigne nakon vremena isteka. Tim treba da definiše konzistentno pravilo za ovakav slučaj i obrazloži ga kroz dizajn i dijagram sekvenci.

U slučaju da korisnik uspešno obavi kupovinu a parking sesija se ne aktivira ili ne produži, potrebno je implementirati mehanizam refundacije troškova istim načinom plaćanja.

Obaveštenja o isteku parkinga

Online parking sistem treba da obavesti korisnika pre isteka aktivne parking sesije. Vreme slanja obaveštenja može biti unapred definisano ili podesivo od strane korisnika.

Obaveštenje treba da sadrži vozilo, parking zonu/lokaciju i vreme isteka. Ukoliko je produženje dozvoljeno, korisniku treba omogućiti da iz aplikacije pokrene proces produženja. Nakon

uspešnog produženja prethodno zakazano obaveštenje mora biti ažurirano u skladu sa novim vremenom isteka.

Payment Service Provider

Servis koji omogućava plaćanje (PSP) predstavlja sistem kojim upravlja super admin. Poslovni model PSP-a je posredovanje između različitih servisa za plaćanje i klijenata. Klijenti žele da podrže različite vrste plaćanja, ali ne žele da brinu o bezbednosti datih funkcija i njihovom održavanju, te se odlučuju za upotrebu ovakvog sistema. Klijent u ovom slučaju je parking sistem, koji se u okviru PSP-a pretplaćuje na proizvoljan skup servisa za plaćanje.

Aplikacija omogućava klijentima:

- registraciju i podršku za različite klijente, a ne samo za parking sistem;
    - Registraciju novih klijenata obavlja super admin, uz obaveznu promenu lozinke kada se klijent prvi put prijavi
- pregled i upravljanje odabranih metoda plaćanja;
- deaktivaciju postojećih metoda plaćanja, uz uslov da uvek postoji bar jedan aktivan način plaćanja;

Plaćanje može da se izvrši na jedan od 4 načina:

1. Plaćanje putem banke - upotrebom platne kartice,
2. Plaćanje putem banke - upotrebom QR koda,
3. Plaćanje putem PayPal-a - kroz PayPal nalog,
4. Plaćanje putem kriptovalute (npr: Bitcoin, Ethereum, Binance Coin...)

Plaćanje putem banke

Plaćanje putem banke podrazumeva protokol komunikacije između različitih učesnika:

- Kupac - korisnik parking sistema koji izvršava plaćanje i ima otvoren račun u banci;
- Prodavac - parking sistem, odnosno pružalac parking usluge, vlasnik usluge koji ima otvoren račun u banci;
- Banka prodavca (Acquirer) - koja pruža servis za online plaćanje, gde kupac unosi podatke o svojoj platnoj kartici,
- Banka kupca (Issuer) - proverava stanje računa kupca i odobrava transakciju ukoliko postoje raspoloživa sredstva.

Napomena: Za potrebe ove specifikacije, podrazumevaćemo da računi svih kupaca kao i račun prodavca pripadaju istoj banci - Acquirer banci.

1. Plaćanje platnom karticom

Nakon što se kupac preusmeri na stranicu za odabir plaćanja na PSP-u, tok podataka je sledeći:

1. Online parking sistem formira zahtev za inicijalizaciju transakcije ka PSP-u. Zahtev treba da omogući identifikaciju klijenta, parking naloga i transakcije. Ovaj korak je univerzalan za sve načine plaćanja.

Parametar	Opis
MERCHANT_ID	ID prodavca, koji se dobije od PSP-a prilikom pretplate *parking sistema* na plaćanje putem banke.
MERCHANT_PASSWORD / API_KEY	Lozinka koja se dobije od PSP-a prilikom odabira plaćanja putem banke. Može da se posmatra i kao api-key koji koristi prodavac - *parking sistem* kako bi svi zahtevi sa tog parking sistema prema PSP-u bili autentifikovani.
AMOUNT	Iznos transakcije.
CURRENCY	Valuta u kojoj se izvršava plaćanje. Sistem treba projektovati tako da podržava različite valute.
MERCHANT_ORDER_ID	Prodavčev ID transakcije. Generiše se nasumično, od strane parking sistema i služi za identifikaciju i praćenje transakcije
MERCHANT_TIMESTAMP	Prodavčev *timestamp* transakcije
SUCCESS_URL	URL na koji će se kupac preusmeriti ako je transakcija uspešna.
FAILED_URL	URL ne koji će se kupac preusmeriti ako je transakcija neuspešna.
ERROR_URL	URL na koji će se kupac usmeriti ako se desila bilo kakva greška.

Tabela 1. Podaci koji se šalju prilikom inicijalizacije transakcije ka PSP-u

   a. Od navedenih podataka, deo klijent šalje PSP-u sa svakim zahtevom za kupovinu, dok deo treba PSP da poseduje za svakog klijenta. Potrebno je proceniti optimalnu razmenu podataka.
   b. SUCCESS_URL, FAILED_URL, ERROR_URL predstavljaju unapred dogovorene url-ove do stranica na parking servisu. Komunikacija između PSP-a i parking servisa za ažuriranje statusa se odvija **asinhrono**. Na osnovu statusa, korisnik *parking sistema* koji je obavio plaćanje će dobiti prikaz sa odgovarajućom porukom. Ova 3 URL-a ne moraju da se šalju uz svaki zahtev već mogu da se definišu dinamički između *parking sistema* i PSP-a.
2. PSP validira zahtev, kreira internu transakciju i formira zahtev prema banci prodavca za dobijanje PAYMENT_URL i PAYMENT_ID parametara. Podaci koji se prosleđuju su navedeni u tabeli 2.

Parametar	Opis
MERCHANT_ID	ID prodavca, koji PSP dobije od ACQUIRER banke prilikom inicijalizacije sistema (ovo može biti unapred definisana vrednost između banke i PSPa i ne treba da bude ista kao MERCHANT_ID iz tabele 1). Ovaj ID banka koristi za identifikaciju ugovorenog trgovca.
AMOUNT	Iznos transakcije
CURRENCY	Valuta u kojoj se izvršava plaćanje. Sistem treba projektovati tako da podržava različite valute.
STAN (System Trace Audit Number)	ID za praćenje transakcije između PSP-a i banke, generisan od strane PSP-a. Kombinacija parametara MERCHANT_ID + STAN + PSP_TIMESTAMP može da se koristi kako bi se ispratio status transakcije u slučaju da PSP ne primi odgovor od banke.
PSP_TIMESTAMP	*timestamp* transakcije kod PSP-a

Tabela 2. Podaci koji se šalju banci u zahtevu za dobijanje Payment_URL i Payment_ID

3. Banka prodavca proverava da li je dobijen zahtev ispravan i autentifikuje PSP. Ako je zahtev validan, generiše PAYMENT_URL i PAYMENT_ID, koji preusmerava kupca sa sajta PSP-a na sajt banke prodavca.
    a. Ispravan zahtev podrazumeva validaciju PSP-a (npr. autentikacija pomoću sertifikata ili HMAC ključeva) kao i validaciju MERCHANT_ID parametra.
4. Na stranici banke prodavca, kupac unosi PAN, SECURITY_CODE, CARD_HOLDER_NAME i datum do kada kartica važi. Izvršava se provera podataka.
    a. Na formi za plaćanje moraju da se nađu logo-i kartica koje sistem prihvata.
    b. Svaki broj kartice (PAN) mora biti validiran *Lunovom* formulom.
    c. Datum mora biti u formatu MM/YY uz obaveznu validaciju.
    d. Jedna forma (payment url) je vezana za tačno jednu transakciju i potrebno ju je vremenski ograničiti i ograničiti je na samo jedan pokušaj plaćanja.
    e. Iznos za plaćanje na formi nije moguće izmeniti.
5. Banka prihvata zahtev i, ako je ispravan kupac (na osnovu validacije PAN-a, datuma i kontrolnog broja kartice) i ima dovoljno novca, banka rezerviše sredstva. Odgovor banke sadrži status transakcije, GLOBAL_TRANSACTION_ID i ACQUIRER_TIMESTAMP.
6. Banka prodavca prosleđuje podatke o statusu transakcije, uz STAN, GLOBAL_TRANSACTION_ID i ACQUIRER_TIMESTAMP PSP-u. PSP čuva status i koristi API parking sistema kako bi se kupac prebacio na stranicu koja prikazuje status izvršavanja transakcije (uspeh, neuspeh, greška).
    a. Parking sistem aktivira parking sesiju isključivo nakon potvrde uspešnog plaćanja.
    b. GLOBAL_TRANSACTION_ID je dozvoljeno čuvati u parking sistemu ukoliko ima potrebe. GLOBAL_TRANSACTION_ID je indikator na osnovu koji klijent (parking servis) može preko PSP-a proveriti status o transakciji.

Napomena: Možete smatrati da se rezervisanjem sredstava završava kupovina. Nije potrebno raditi *clearing & settlement* na nivou banke.

2. Plaćanje QR kodom

Tok podataka kod plaćanja QR kodom i kod plaćanja karticom se razlikuju samo u načinu realizacije stavke 4. Kada se plaća platnom karticom prikazuje se odgovarajuća forma, kada se plaća QR kodom prikazuje se QR kod koji je potrebno skenirati.

QR kod treba da sadrži valutu i iznos koji se plaća, broj računa primaoca (prodavca), naziv primaoca itd. Potrebno je implementirati generator QR koda i validator po uzoru na IPS NBS. Validan QR kod je onaj kod koji omogućava IPS skeniraj & plati iz bilo koje mBanking aplikacije. S obzirom na to da NBS podržava samo kupovinu u RSD valuti, potrebno je iznos konvertovati u dinarsku protivvrednost po kursu banke koju aplikacija simulira. Ukoliko ne možete da pronađete API za kursnu listu te banke, odaberite bilo koji API koji proverava kurs u realnom vremenu.

PSP mora imati mehanizam kojim proverava konačan status QR transakcije i obaveštava parking sistem. Parking sesija se aktivira tek nakon potvrde uspešne uplate.

Treba napraviti mobilnu aplikaciju banke kupca koja će da vrši skeniranje. Na mobilnoj aplikaciji je potrebno omogućiti prijavu različitih klijenata, i izvršiti plaćanje. Prilikom skeniranja QR koda, račun sa kog se vrši plaćanje je račun *ulogovanog korisnika*.

3. Plaćanje putem PayPal-a

Kupac koji je odabrao plaćanje putem PayPal-a biva preusmeren na PayPal sajt. Ovde se kupac prijavljuje na svoj PayPal nalog, sa kog izvršava uplatu na nalog prodavca. Radi uspostavljanja ove komunikacije, potrebno je analizirati i upotrebiti PayPal API i testno/sandbox okruženje.

Informacije o PayPal transakciji treba čuvati na PSPu i u *parking servisu* u meri potrebnoj za povezivanje plaćanja sa parking nalogom (slično kao kod kartičnog plaćanja). Nakon potvrde uspešnog plaćanja PSP obaveštava parking sistem, koji aktivira parking sesiju.

4. Plaćanje kriptovalutom

Za plaćanje kriptovalutom potrebno je koristiti odgovarajući API i testnu mrežu. Koristeći Bitcoin API (ili neki alternativni API) izvršiti plaćanje na poseban *wallet* koja odgovara *parking servisu*.

Iznos za plaćanje u kriptovaluti treba da odgovara iznosu u fiat valuti iz *parking servisa* u realnom vremenu. Testiranje plaćanja može se izvršiti postojećim novčanikom (walletom) ili možete implementirati novi novčanik. Za implementaciju koristiti odgovarajuću test mrežu.

PSP prati transakciju na testnoj mreži i nakon potvrde plaćanja obaveštava parking sistem. Potrebno je čuvati identifikator kripto transakcije i vezu sa internom PSP i parking transakcijom.

Bezbednost

S obzirom na kontekst PSP-a i elektronskog plaćanja, potreban je najviši nivo bezbednosti. Neophodno je proučiti PCI DSS standard v4.0.1, izdvojiti relevantne zahteve i implementirati kontrole koje ispunjavaju date zahteve.

Za PCI DSS standard, potrebno je fokusirati se na:

- *Protect stored account data* (kompletan zahtev 3)
- *Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks* (kompletan zahtev 4)
- *Implement strong access control measures* (kompletan zahtev 7)
- *Identify Users and Authenticate Access to System Components* (zahtev 8)
    - MFA implementirati pomoću Authenticator aplikacija (Google ili Microsoft)
- *Track and monitor all access to network resources and cardholder data* (zahtev 10)

Posebnu pažnju potrebno je posvetiti:

- zaštiti podataka o platnim karticama i zabrani nepotrebnog čuvanja osetljivih autentifikacionih podataka;
- jakoj autentifikaciji i kontroli pristupa administrativnim i servisnim funkcijama;
- bezbednoj komunikaciji između parking sistema, PSP-a i servisa za plaćanje;
- evidentiranju i praćenju pristupa i događaja povezanih sa transakcijama;
- zaštiti tajni, API ključeva i drugih kredencijala;
- sprečavanju neovlašćene izmene iznosa, valute, parking naloga ili statusa transakcije.

Visoka dostupnost i skaliranje

Aplikacija takođe treba da ima sledeća svojstva:

- PSP treba da bude *loosely-coupled* sa parking sistemom: PSP treba da ima API koji je prilagođen radu sa raznim sistemima i prodavcima, od sistema koji imaju jednog prodavca (npr. klasična veb-prodavnica) do sistema koji uslužuje više prodavaca.
- PSP treba da bude plagabilan: PSP treba da bude plagabilan, svaki vid plaćanja predstavlja jedan plug-in. PSP treba projektovati tako da se novi servisi za plaćanje mogu podržati što jednostavnije (npr. Payoneer, druge kriptovalute, itd).
- PSP treba da ima arhitekturu koja podržava visoku dostupnost: *High-availability* arhitektura podržava jednostavno skaliranje sistema. Integracija sa novim prodavcem (tipa veb-prodavnica) ili novim načinom plaćanja treba da se omogući bez gašenja PSP-a. PSP mora biti uvek dostupan svim klijentima.
- Ceo sistem je neophodno pokrenuti na minimum 2 računara ili na *cloud-u*.
- Komunikacija HTTPS-om ili nekim drugim *secure* protokolom (poput gRPCs) je obavezna.

Obrada specijalnih slučajeva

Specijalne slučajeve potrebno je implementirati na nivou odgovarajućih komponenti sistema, uz obezbeđivanje njihovog pravilnog ponašanja za sve primenljive načine plaćanja.
Specijalni slučajevi:

1. promena iznosa tokom procesa plaćanja
2. mehanizam provere statusa transakcije u slučaju da jedan ili više servisa nisu dostupni tokom procesa plaćanja
3. mehanizam obrade transakcije u slučaju da korisnik greškom odustane od plaćanja (slučajno zatvori tab, izgubi internet konekciju i sl.)
4. dvostruko plaćanje (npr. korisnik dvaput klikne na dugme za plaćanje)
5. kašnjenje potvrde – parking sistem mora moći naknadno da proveri konačan status transakcije i uskladi stanje bez oslanjanja isključivo na redirect korisnika.
6. Istovremeno produženje – sistem mora sprečiti ili pravilno obraditi dva paralelna zahteva za produženje iste parking sesije.
7. Istek parkinga tokom plaćanja produženja – potrebno je jasno definisati pravilo i očuvati trag svih promena statusa.
8. Konkurentno plaćanje na isti ili sa istog računa

Testiranje performansi

Potrebno je pripremiti testove opterećenja i demonstrirati ponašanje arhitekture kompletnog sistema za sledeće scenarije:

1. Bar 2 hiljade korisnika istovremeno kupuju parking karte putem platne kartice (posebno obratiti pažnju na iznos na računu - ovo će zavisiti od odabranog načina za rešavanje poslednje tačke iz poglavlja “Obrada specijalnih slučajeva”)
2. Preveliko opterećenje PSP-a od strane jednog klijenta pri čemu obrada plaćanja i obaveštavanje ostalih klijenata moraju nastaviti normalno (klijent = webshop aplikacija koja se integriše sa PSP-om, ovde je to parking servis)
    - Da biste uspešno rešili ovaj problem, morate demonstrirati postojanje najmanje još jednog klijenta koji se integriše sa PSP-om i istovremeno šalje zahteve
3. Usporavanje celog PSP-a namerno sporim endpoint-om za ažuriranje statusa transakcije (odnosi se na *endpoint parking servisa* koji PSPgađa da potvrdi status kupovine)
4. Otkaz jedne instance PSP-a a potom i banke tokom obrade velike količine transakcija (preko 2 hiljade)
    - Pripremiti skriptu koja će nakon potvrditi da se otkazom PSPa ili banke nisu izgubile transakcije i nije došlo do dvostruke naplate

Za svaki scenario je potrebno u tabelaroj formi prikazati u kom trenutku dolazi do problema (na koji endpoint utiče ili na koji korak u toku plaćanja), koja komponenta je ugrožena i koji mehanizam ste implementirali kao rešenje.

Kontrolne tačke

Timovi	KT 1 [15 bodova]	KO [35 bodova]
Četvoro člani	- [zajedno] Dizajn sistema, model podataka i dijagram sekvenci - [student 1] PSP Dashboard – klijentski i administratorski portal. - [student 2] Plaćanje karticom i validacija forme za plaćanje. - [student 3] Implementacija parking sistema i aktiviranje parking sesije. - [student 4] plaćanje putem QR koda	- [student 1] Plaćanje putem PayPal-a - [student 2] Produženje parking sesije i obaveštenja o isteku parkinga - [student 3] Plaćanje kriptovalutom - [student 4] Obrada specijalnih slučajeva - [svaki student po 1 tačka] Testiranje performansi - [zajedno] Bezbednost - primena PCI DSS standarda, visoka dostupnost i skaliranje PSP sistema
Tročlani	- [zajedno] Dizajn sistema, model podataka i dijagram sekvenci - [student 1] PSP Dashboard – klijentski i administratorski portal. - [student 2] Plaćanje karticom i validacija forme za plaćanje. - [student 3] Implementacija parking sistema, aktiviranje parking sesije, plaćanje putem QR koda	- [student 2] Produženje parking sesije, obaveštenja o isteku parkinga i obrada specijalnih slučajeva (tačka 6 i 7) - [student 1] Plaćanje putem PayPal-a i obrada specijalnih slučajeva (tačka 1, 3 i 4) - [student 3] Plaćanje kriptovalutom i obrada specijalnih slučajeva (tačka 2, 5 i 8) - [student 2 - 2 tačke, ostali po 1] Testiranje performansi - [zajedno] Bezbednost - primena PCI DSS standarda, visoka dostupnost i skaliranje PSP sistema
Dvočlani	- [zajedno] Dizajn sistema, model podataka i dijagram sekvenci - [student 1] PSP Dashboard – klijentski i administratorski portal, aktiviranje parking sesije plaćanje putem QR koda - [student 2] Implementacija parking sistema, plaćanje karticom i validacija forme za plaćanje.	- [student 1] Produženje parking sesije, obaveštenja o isteku parkinga, plaćanje putem PayPal-a i obrada specijalnih slučajeva (tačka 6 i 7) - [student 2] Plaćanje kriptovalutom i obrada specijalnih slučajeva (tačka 1, 2, 3, 4, 5 i 8) - [svaki student po 2 tačke] Testiranje performansi - [zajedno] Bezbednost - primena PCI DSS standarda, visoka dostupnost i skaliranje PSP sistema
Jednočlani	- Dizajn sistema, model podataka i i dijagram sekvenci. - Implementacija parking sistema. - Aktiviranje parking sesije. - Plaćanje karticom. - Validacija forme za plaćanje.	- Plaćanje putem QR koda. - Produženje parking sesije. - Obaveštenja o isteku parkinga. - Obrada specijalnih slučajeva. - Testiranje performansi - prvi zahtev. - Bezbednost - Primena PCI DSS standarda koji se odnose na plaćanje putem banke.